

Why Aligned Models Are Not Enough: Toward Channel-Level Safety for Agent-to-Agent Communication

Amr Gomaa

German Research Center for Artificial Intelligence (DFKI)
amr.gomaa@dfki.de

Abstract

AI agents now act and communicate on behalf of users, and safety can no longer be treated as a property of any single model. Every time two agents talk, a trust boundary is crossed: on one side is the user’s private data, and on the other is free-form language from an external agent that may be adversarial. A persuasive conversation, developed over several turns, can slip past a model’s safety training without ever triggering a refusal. This paper argues that safety should be enforced at the communication channel itself, rather than relying solely on the model. We support this argument in two ways. First, we point to recent empirical evidence that agent-to-agent conversations are systematically exploitable. Second, we describe a dual-firewall architecture that shows how structural constraints on the channel can be implemented in practice. We then outline a set of open research problems that, in our view, must be solved before agentic systems can be deployed safely at scale.

1 Introduction

Agent-to-agent communication is repeating a familiar pattern from the early internet: connectivity first, security later. When an AI agent negotiates a travel plan, an insurance policy, or a real estate deal on behalf of a user, every message it sends or receives crosses a boundary. On one side sits the user’s personal data. On the other sits free-form text from an external agent that may not be cooperative (or even be malicious). The two sides create different kinds of risk, and both arise on every turn.

The dominant response is to make models more aligned, more instruction-following, and more safety-trained. We see this as an insufficient framing of the problem. Alignment is a behavioral target, not a structural guarantee. A persuasive message can bypass alignment without ever triggering a refusal. So can a request that is contextually plausible and developed over several turns, or a piece of social engineering that mimics a legitimate dialogue. The deeper issue is that the model is being asked to defend a boundary that the communication protocol itself does not define. There is no clear

specification of what the external agent is allowed to say, and so the model has nothing concrete to enforce.

This paper argues that the inter-agent communication channel itself must be constrained. Rather than relying on aligned models to resist every possible manipulation, the system should be built so that most manipulations cannot reach the model in the first place. The principle is well established in computer security; firewalls, type systems, and protocol verifiers all operate this way. What is new is applying it to natural-language agent communication, where messages are free-form text rather than structured packets, and the range of possible attacks is therefore much larger.

The remainder of the paper proceeds as follows. Section 2 grounds the problem empirically using our published ConVerse benchmark [Gomaa *et al.*, 2025]. Section 3 describes our recent preprint of a dual-firewall architecture [Abdelnabi *et al.*, 2025] as a proof of concept for structural channel constraints. Section 4 outlines the open research agenda for channel-level safety.

2 The Attack Surface Is Contextual

A growing body of work has begun to characterize the risks that arise when AI agents communicate. Prompt injection attacks [Perez and Ribeiro, 2022; Greshake *et al.*, 2023] showed that instructions embedded in external data, such as a webpage or a retrieved document, can override what the user actually asked for. Later work has built defenses for the case where the external data is fixed and untrusted [Debenedetti *et al.*, 2025; Costa *et al.*, 2025].

Agent-to-agent communication introduces a harder problem. The external agent is participating in a dialogue that, on the surface, appears to be exactly the kind of cooperation the system was designed to support. There is no clean line between what counts as data and what counts as instruction. Attacks take the form of contextually plausible questions, urgency framings, and persuasion that unfold across multiple turns.

To measure this concretely, we use ConVerse [Gomaa *et al.*, 2025], a recent benchmark for agent-to-agent safety. ConVerse simulates conversations between a user’s personal assistant and an external service provider in three domains: travel planning, real estate, and insurance. The benchmark contains 864 attacks distributed across 12 user personas. Every attack is embedded inside a multi-turn conversation that

otherwise looks legitimate.

Across seven frontier models, including GPT-5, Claude Sonnet 4, and Gemini 2.5 Pro, the attack success rate (ASR) reaches 88% for privacy attacks and 60% for security attacks. One counter-intuitive finding is that *stronger models leak more*. Models that are better at completing the task also tend to disclose more private information. The same contextual sensitivity that makes them helpful also pushes them to overshare. Even data that has nothing to do with the task itself leaks at substantial rates (57–71% ASR), which suggests that agents do not reliably keep different categories of information separate. Security attacks are more subtle. In email manipulation, the external agent frames a harmful action, such as sending an email containing sensitive content, as a normal step in the task. These attacks succeed in up to 100% of cases in some domains. Upselling and preference manipulation attacks exploit the inherent ambiguity of open-ended planning. A legitimate clarifying question and a manipulative upsell can look almost identical at the surface, and current models do not reliably tell them apart.

Two design choices in the benchmark are worth highlighting. First, the attacks are *contextually grounded*. They unfold across multiple turns, embedded inside conversations that otherwise look legitimate, rather than appearing as obvious adversarial prompts. Second, the benchmark sorts user data into three tiers based on relevance to the task: unrelated to the task, related but private, and related and useful. This three-tier split makes it clear that the challenge is not binary filtering but appropriate *abstraction*. Agents often need to share information that is relevant to the task; the issue is that they share it at too fine a level of detail [Nissenbaum, 2004; Barth *et al.*, 2006].

The pattern across these results is consistent: the attack surface is the conversation itself. Defenses that operate at the model level, such as alignment, prompting, and refusal training, have to fight every message individually. A more durable approach is to shrink the surface itself by constraining what can cross the channel in the first place.

3 Structural Channel Constraints as a Defense Primitive

Our recent work on a dual-firewall architecture [Abdelnabi *et al.*, 2025] provides a concrete example of what structural channel constraints look like in practice. The system deploys two separate firewalls at the two boundaries surrounding the user’s personal assistant: one between the assistant and the external agent, and one between the assistant and the user’s own data store. Both firewalls follow a single principle. Any given task defines a specific context, and the information that flows on either side of the assistant typically goes far beyond what that context actually needs. The job of the firewalls is to keep only the parts that match the task and to reshape the rest.

Language Converter Firewall. This firewall sits between the external agent and the assistant. Instead of asking the assistant to resist every possible manipulation, the firewall first translates the external agent’s free-form message into a strict, task-specific format. The format is defined by a small, fixed

set of allowed fields and value types, and these are learned automatically from examples of normal, non-malicious conversations. A simple rule-based checker then validates every field. Any content that does not meet the specification is automatically rejected, with no LLM involved in the decision. Free-text fields, such as hotel names, are replaced with placeholder identifiers before they reach the assistant. The security guarantee here is structural rather than behavioral: persuasive framing, urgency tactics, and embedded instructions have no place in the format’s vocabulary, so they cannot reach the assistant at all.

Data Abstraction Firewall. This firewall sits between the user’s personal data store and the assistant. Earlier work, such as AirGapAgent [Bagdasarian *et al.*, 2024], treated this as a binary problem in which each piece of data is either passed through or blocked. The data abstraction firewall instead applies learned rules that rewrite the data at an appropriate level of detail before the assistant ever sees it. The rules are learned from pairs of conversations, one normal and one with an attack. The contrast between the two reveals which disclosures are appropriate for the task and which are not. The firewall is also deliberately limited in what it sees. It never reads the external agent’s messages, so a manipulation attempt in those messages cannot influence what the firewall decides to share.

The empirical results are strong. On the ConVerse benchmark, the dual firewall reduces the privacy ASR from 84% to 10% for GPT-5, and from 73% to 17% for Claude Sonnet 4. The security ASR drops from 60% to 3% and from 11% to 1% for the same two models, respectively. At the same time, task quality is preserved. Plan-quality ratings actually improve for most models. A plausible explanation is that the firewalls strip away distracting manipulation attempts and pass cleaner, more focused information to the assistant.

Component-wise experiments show that the two firewalls handle different attack types. The Language Converter is the main defense against security attacks; on its own, it reduces the security ASR from 55% to 1%. The Data Abstraction Firewall is the main defense against privacy attacks. The two together are substantially stronger than either alone. The comparison with AirGapAgent makes the value of granularity-aware abstraction concrete. On GPT-5, the dual firewall achieves 5.5% privacy ASR, compared to 67.3% for the binary approach. The gap is largest on the related-and-useful tier of data (23.8% vs. 76.2%). This is exactly the tier where binary filtering fails: the agent does need to share something to make progress on the task, but it should do so at a lower level of detail. Knowing how to abstract is a qualitatively different operation from deciding whether to share at all.

4 Open Research Roadmap

The dual-firewall results show that structural channel constraints are both technically feasible and empirically effective. They also expose several open problems. We outline below what we see as the most important ones; together, they form a research agenda and a future roadmap for channel-level safety.

Formal information-flow bounds. The current architecture provides structural guarantees field by field: a fixed vocabulary, type-checked values, and anonymized free text. It does not yet provide a guarantee about how much information leaks when several fields are combined. Even when each field has been abstracted on its own, several fields together can still narrow down a user. A travel itinerary, combined with an abstracted age range and a rare allergy, can identify a single person even though no single field is precise. What is needed is a guarantee, available at deployment time, that bounds the total information leaked by any pattern of disclosures permitted by the firewall. Classical results from statistical privacy [Shokri *et al.*, 2017] are the natural starting point, but extending them is not straightforward. Agent communication is sequential and domain-specific, and most existing privacy bounds do not adequately cover this setting.

Policy languages for contextual norms. The current system learns its rules from examples. This works well when enough normal and attack conversations are available, but it leaves a gap. There is no formal language for writing down norms about what information is appropriate in what context [Nissenbaum, 2004]. Without one, a rule-generation system has nothing to start from when examples are scarce, and human experts have no precise way to specify rules by hand. A useful policy language would bridge two levels. At the high level are normative principles, such as “financial details should be shared only at a level of detail appropriate to the current task.” At the low level are concrete, executable rules, such as “round any numeric field tagged as financial to the nearest \$500.” Bridging the two would make the system auditable, transferable across domains, and easier to check for regulatory compliance, including under the transparency requirements of the EU AI Act.

Compositional safety across agent networks. The current architecture only protects one-to-one conversations between two agents. Real deployments will be larger. A user’s assistant may coordinate with travel, insurance, and healthcare agents simultaneously and may itself be working under an orchestrating agent that distributes subtasks. Norms about appropriate disclosure do not combine in straightforward ways. A rule that permits sharing a user’s general health status with a healthcare agent does not automatically authorize sharing it with a travel agent that has observed the healthcare conversation. How such norms should be written, passed along, and enforced when information flows through several agents is, to our knowledge, an open problem. The firewalls provide building blocks for the pairwise case, but a theory for combining them across larger networks has yet to be developed.

Adversarial exploitation of valid messages. One class of attacks is harder to block than the others. An external agent can propose items that are entirely valid under the protocol: correctly typed, within range, and matching the format. The items themselves, however, are chosen to exploit the user’s preferences or to exceed the constraints the user has stated. Such messages pass the verifier because, structurally, they are not wrong. The Language Converter strips out persuasive framing before the assistant sees the message; ironically, this also removes some of the cues the assistant might other-

wise have used to spot a problem. Closing this gap requires reasoning about the *intent* behind a message, not only its content. This kind of pragmatic inference, which is to say figuring out why a message is being sent, not just what it says, is something current models do not yet perform reliably. One direction is to add provenance annotations to the protocol. Each field would carry a flag indicating whether its value is plausible given typical domain values. A five-star city-center hotel in Paris priced at \$30 per night, for example, would be flagged automatically, and the assistant would have to verify the claim before acting on it.

Scalability to unstructured domains. The Language Converter works best when the relevant fields and values can be listed in advance. Domains like travel, real estate, and insurance fit this pattern well; there is a fixed set of things one can ask about a flight, an apartment, or an insurance plan. In less structured domains, such as creative collaboration or open-ended research assistance, many fields are inherently free text. There is no clean vocabulary to enforce, and so anonymization of strings becomes the main remaining defense on the incoming side. This may come at a cost in usefulness. The Data Abstraction Firewall scales more naturally to these domains. Its rules operate on the user’s own data, so its effectiveness does not depend on the structure of the external conversation. What is needed is a clear characterization of which domains the channel constraints fully cover and which they only partially cover. We then need a hybrid architecture that falls back to model-level defenses only where the structural layer cannot reach.

Lightweight enforcement through distillation. Both firewalls currently use frontier LLMs for conversion and abstraction. In production settings, where latency and cost matter, this is a bottleneck. Each firewall adds one extra LLM call per turn. The call is short and substantially cheaper than the main interaction, but it still depends on large-model inference. The learned rules can plausibly be distilled into much smaller, fine-tuned models. The argument has two parts. *Learning* the rules benefits from the capacity of a large model. *Enforcing* the rules, once they have been written down, is a much narrower problem and may be solvable with small fine-tuned models, or even with rule-based parsers. The architecture already separates an LLM converter from a deterministic verifier; the same split should extend to the abstraction side.

Norm evolution and feedback. The current system treats rules as fixed once they have been learned. In practice, both the norms of a domain and an individual user’s preferences can shift over time. A user who is comfortable sharing their general location for travel planning may no longer be comfortable doing so after a data breach at a prior service provider. The fact that the architecture separates rules from the engine that enforces them makes updates easier in principle. The rules can be revised without changing the enforcement code. What remains open is how to use feedback from real interactions. The user, or a trusted auditor, may disagree with how the firewall has handled a particular case. We need a way to feed that disagreement back into the rules without giving an attacker a new way in through the feedback channel itself.

5 Conclusion

The ConVerse results [Gomaa *et al.*, 2025] make a clear case that agent-to-agent communication is a systematic, exploitable attack surface, and that model alignment alone does not close it. The dual-firewall architecture [Abdelnabi *et al.*, 2025] shows that placing structural constraints on the channel can cut attack success rates by over 90%. Task quality is preserved and, in many cases, improves. We have sketched six open problems above: formal information-flow bounds, policy languages for contextual norms, compositional safety across agent networks, adversarial exploitation of valid messages, scalable enforcement through distillation, and norm evolution. In our view, these problems form the core of a future roadmap for safe agentic AI. Building this infrastructure while the ecosystem is still small is far cheaper than retrofitting it once agent-to-agent communication is as pervasive as the open internet.

References

- [Abdelnabi *et al.*, 2025] Sahar Abdelnabi, Amr Gomaa, Eugene Bagdasarian, Per Ola Kristensson, and Reza Shokri. Firewalls to Secure Dynamic LLM Agentic Networks. *arXiv preprint arXiv:2502.01822*, 2025.
- [Bagdasarian *et al.*, 2024] Eugene Bagdasarian, Ren Yi, Sahra Ghalebikesabi, Peter Kairouz, Marco Gruteser, Sewoong Oh, Borja Balle, and Daniel Ramage. Air-GapAgent: Protecting Privacy-Conscious Conversational Agents. In *CCS*, 2024.
- [Barth *et al.*, 2006] Adam Barth, Anupam Datta, John C Mitchell, and Helen Nissenbaum. Privacy and contextual integrity: Framework and applications. In *IEEE symposium on security and privacy (S&P)*, 2006.
- [Costa *et al.*, 2025] Manuel Costa, Boris Köpf, Aashish Kolluri, Andrew Paverd, Mark Russinovich, Ahmed Salem, Shruti Tople, Lukas Wutschitz, and Santiago Zanella-Béguelin. Securing AI Agents with Information-Flow Control. *arXiv preprint arXiv:2505.23643*, 2025.
- [Debenedetti *et al.*, 2025] Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating Prompt Injections by Design. *arXiv preprint arXiv:2503.18813*, 2025.
- [Gomaa *et al.*, 2025] Amr Gomaa, Ahmed Salem, and Sahar Abdelnabi. ConVerse: Benchmarking Contextual Safety in Agent-to-Agent Conversations. *arXiv preprint arXiv:2511.05359*, 2025.
- [Greshake *et al.*, 2023] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you’ve signed up for: Compromising real-world llm-integrated applications with indirect prompt injection. In *AISeC*, 2023.
- [Nissenbaum, 2004] Helen Nissenbaum. Privacy as contextual integrity. *Wash. L. Rev.*, 79:119, 2004.
- [Perez and Ribeiro, 2022] Fábio Perez and Ian Ribeiro. Ignore previous prompt: Attack techniques for language models. *arXiv preprint arXiv:2211.09527*, 2022.
- [Shokri *et al.*, 2017] Reza Shokri, Marco Stronati, Congzheng Song, and Vitaly Shmatikov. Membership inference attacks against machine learning models. In *IEEE symposium on security and privacy (S&P)*, 2017.